

Post-Incident Review & Corrective Action Report

Lessons learned, root-cause confidence, action ownership, and closure validation

Review Standard

The post-incident review converts incident evidence into control improvements. The goal is not blame; it is to identify what failed, what worked, what delayed response, and which corrective actions measurably reduce recurrence or impact.

Area	Finding	Corrective action	Owner	Priority	Target	Validation
Detection	Sensitive export activity lacked a high-confidence alert.	Create alert for abnormal bulk export volume and privileged export actions.	SOC Lead	High	30 days	Test event generates actionable alert with correct context.
Vulnerability Mgmt	Internet-facing critical issue missed remediation target.	Enforce 7-day critical SLA with exception escalation and asset-owner reporting.	Infra Lead	Critical	14 days	Scan confirms closure; overdue dashboard reviewed.
Identity	Service account permissions exceeded required scope.	Reduce privileges and assign named owner; rotate secret.	App Owner	High	21 days	Access test confirms least privilege; owner recorded.
IR Process	Contact tree required manual lookup during escalation.	Maintain current incident contact roster and quarterly validation.	IR Lead	Medium	30 days	Tabletop confirms contacts reachable.
Recovery	Restore evidence was not recent enough for confidence.	Quarterly restore testing with documented RTO/RPO results.	IT Ops	High	60 days	Successful restore test and signed evidence.
Logging	Selected admin events were missing from SIEM.	Onboard required admin/audit sources and validate parsing/retention.	SOC / IT	High	30 days	Search and alert validation completed.

Root Cause Confidence

- **Confirmed:** Direct evidence establishes the cause.
- **Probable:** Multiple evidence sources support the conclusion, but one or more gaps remain.
- **Possible:** Plausible explanation requiring additional evidence.
- Reports should distinguish confirmed facts from hypotheses so corrective actions are proportionate to evidence.

Lessons-Learned Questions

- Did detection fire early enough, and did it include enough context?
- Was severity assigned correctly and quickly?
- Did containment reduce risk without destroying needed evidence?
- Were owners, contacts, and escalation paths clear?
- Did recovery rely on tested processes and trusted data?
- What control would most reduce likelihood or impact next time?
- How will we prove each corrective action actually works?